

MODULE 41 · EXAM STRATEGY - ALL DOMAINS

Practice exam 2 of 4

20 questions. Same weighting, different traps – and several questions where the obvious answer is the near miss.

QUESTIONS 20 PASS MARK 15 of 20 HOLD 9 seconds

Security Hub CSPM is enabled with the AWS Foundational Security Best Practices standard. Several controls relating to EC2 and RDS show a status of no data, while controls relating to IAM and S3 report normally.

AWS Config is enabled in the account and the delegated administrator is configured correctly.

What is the MOST likely cause?

- ☐ A Those controls are not supported in the account's Region
- ☐ B Security Hub CSPM needs 24 hours to populate after enabling a standard
- ☐ C The Config recorder is not recording the EC2 and RDS resource types those controls evaluate
- ☐ D The Security Hub service-linked role lacks permission to read EC2 and RDS

◆ PAUSE AND DECIDE

What is the MOST likely cause?

- A

 Region does not support them
Would affect a whole standard or none, not a coherent subset by resource type. IAM and S3 controls work in the same Region.
- B

 Needs 24 hours
True immediately after enabling. It does not explain a persistent pattern split cleanly along resource-type lines.
- C

 The Config recorder is not recording those resource types
Correct. Security Hub CSPM controls are service-linked Config rules. A resource type the recorder ignores produces no configuration items, so nothing evaluates.
- D

 Service-linked role lacks permission
That role is managed by AWS. Permission failures surface as errors, not as a clean absence of data.

DOMAIN 1

'Config is enabled' is not 'Config is recording that resource type'. Security Hub CSPM inherits the recorder's scope.

A company must centralise application logs from 90 member accounts into a single security account in near real time, so that a SIEM can consume one stream rather than 90. The logs are written to CloudWatch Logs in each member account.

The security team wants the minimum ongoing operational effort.

What should the company implement?

- ☐ A A CloudWatch Logs destination in the security account, with subscription filters in each member account
- ☐ B A Lambda function in each account exporting log events to a central S3 bucket hourly
- ☐ C CloudWatch Logs cross-account observability, which streams log data to the SIEM
- ☐ D An organization CloudTrail trail with the log groups added as data event sources

◆ PAUSE AND DECIDE

What should the company implement?

- A

A Logs destination with subscription filters
Correct. The destination fronts a Kinesis or Firehose stream, and subscription filters push in near real time - deployable to 90 accounts by StackSet.
- B

Lambda exporting hourly
Not near real time, and it is 90 functions to deploy, permission, monitor and pay for. Maximum operational effort.
- C

Cross-account observability
The sharpest distractor - it genuinely centralises visibility across accounts. It is a console and query experience, not a stream a SIEM consumes.
- D

Organization trail with log groups as data events
CloudTrail records API activity. Application log events in CloudWatch Logs are not CloudTrail data events.

DOMAIN 1

Cross-account observability is for people looking at dashboards. A destination plus subscription filters is for machines consuming a stream.

At 03:20 a single IAM role generates roughly 40 times its usual volume of DescribeInstances and DescribeSecurityGroups calls across every Region, over about eleven minutes. No calls failed and no resources changed.

The team wants a detection that would have flagged this pattern automatically.

What should the team enable?

- ☐ A GuardDuty Runtime Monitoring on the account
- ☐ B CloudTrail Insights on the trail
- ☐ C A metric filter on DescribeInstances with a CloudWatch alarm
- ☐ D AWS Config with a rule detecting unusual describe activity

◆ PAUSE AND DECIDE

What should the team enable?

- A

GuardDuty Runtime Monitoring
Inspects process and file activity on hosts and containers. This is control-plane API volume, which Runtime Monitoring does not observe.
- B

CloudTrail Insights
Correct. Insights baselines normal API call volume and error rates and raises an event on deviation – exactly a 40x spike over eleven minutes.
- C

Metric filter and alarm
Requires a static threshold chosen in advance, per API and per role. It catches the call you anticipated and misses the next pattern.
- D

A Config rule
Config evaluates resource configuration. No resources changed, so Config sees nothing at all.

DOMAIN 1

Reconnaissance is normal calls at abnormal volume. Nothing failed and nothing changed – only a volume baseline sees it.

GuardDuty raises a high-severity finding for credential exfiltration: an EC2 instance role's credentials were used from an IP address outside AWS. Before deciding on containment, the incident lead must establish which other resources that role touched, over what period, and whether other principals show related behaviour.

The organisation runs GuardDuty, Security Hub CSPM, Detective and Config.

Which service is designed for this step?

- ☐ A Security Hub CSPM, aggregating related findings by severity
- ☐ B AWS Config, using the resource timeline for each affected resource
- ☐ C GuardDuty, by raising the finding's severity threshold to surface related findings
- ☐ D Amazon Detective, following the finding into its behaviour graph

◆ PAUSE AND DECIDE

Which service is designed for this step?

- A

 Security Hub CSPM aggregation
Aggregates and scores findings. It tells you what was found, not what the principal did across time and resources.
- B

 Config resource timelines
Answers what a resource looked like when. Reconstructing a principal's activity resource by resource is the manual work Detective removes.
- C

 Raise the severity threshold
Changes which findings surface, not what you know about one. GuardDuty detects; it does not investigate.
- D

 Detective's behaviour graph
Correct. Detective is built for exactly this – the scope and impact of a finding, across principals, resources and time.

DOMAIN 2

Skill 2.2.3 is 'validate findings to assess scope and impact', added in C03. Detective is the service that answers it.

A company wants EC2 instances that GuardDuty flags with a specific high-severity finding type to be isolated automatically within two minutes, at any hour, without an engineer being present.

Isolation means applying a no-access security group and detaching the instance from any Auto Scaling group.

What should the company build?

- ☐ A CloudWatch alarm on the GuardDuty finding metric, notifying an on-call engineer
- ☐ An EventBridge rule matching the finding type, invoking an SSM Automation runbook that performs the isolation
- ☐ A Config rule with SSM Automation remediation, evaluating instance compliance
- ☐ Security Hub CSPM automation rules, which change finding workflow status and isolate the resource

◆ PAUSE AND DECIDE

What should the company build?

- A

 Alarm notifying on-call
The requirement says without an engineer being present. Paging someone at 3am is the process this replaces.
- B

 EventBridge rule invoking an SSM Automation runbook
Correct. GuardDuty findings are EventBridge events, so a rule can match the finding type and invoke a runbook that isolates within seconds.
- C

 Config rule with remediation
Config evaluates configuration. A compromised instance is configured exactly as intended - there is no violation to detect.
- D

 Security Hub automation rules
The best distractor. Automation rules update finding fields - severity, workflow status, suppression - and do not act on the underlying resource.

DOMAIN 2

Security Hub automation rules change the finding. EventBridge plus SSM changes the world.

A container in an EKS cluster has been compromised. The security team must preserve evidence from the container and the node, and stop the container's outbound traffic, while other pods on the same node continue running.

The cluster uses managed node groups on EC2.

What is the MOST appropriate approach?

- ☐ A Terminate the node; the Auto Scaling group replaces it and the compromise ends
- ☐ B Apply an isolating security group to the node, then snapshot its volume
- ☐ C Apply a deny-all Kubernetes network policy to the pod, capture the container filesystem and node volume snapshot, then cordon the node
- ☐ D Delete the pod so the ReplicaSet recreates it on a different node

◆ PAUSE AND DECIDE

What is the MOST appropriate approach?

A Terminate the node

Destroys all evidence and every other pod on it. Eradication before evidence, plus collateral damage the requirement forbids.

C Deny-all network policy on the pod, capture, then cordon

Correct. A network policy isolates that pod alone, capture preserves container and node evidence, and cordoning stops new scheduling without evicting.

B Isolating security group on the node

Isolates at node level, stopping every other pod on that node. The requirement says they must keep running.

D Delete the pod

Destroys the container's state and may reschedule the same compromised image elsewhere. It relocates the problem and loses the evidence.

DOMAIN 2

Container isolation happens at the pod, not the node. Isolating the node punishes every workload sharing it.

During an incident, a specific /24 address range must be blocked from reaching a fleet of instances in a public subnet within minutes. The instances sit behind a load balancer and are served by four different security groups.

The block must apply regardless of what each security group permits.

What should be used?

- ☐ A An inbound Deny rule for that CIDR in the subnet's network ACL
- ☐ B Removing the 0.0.0.0/0 inbound rules from all four security groups
- ☐ C An AWS WAF IP set rule blocking the range on the load balancer
- ☐ D A route table entry blackholing the CIDR

◆ PAUSE AND DECIDE

What should be used?

- A

 A Deny rule in the network ACL
Correct. NACLs are the only subnet-level control with an explicit Deny, and it applies to every instance regardless of security groups.
- B

 Remove the open inbound rules
Security groups have no Deny. Removing allow rules blocks everyone, not one range – and means editing four groups correctly under pressure.
- C

 A WAF IP set on the load balancer
Genuinely effective for HTTP traffic through that listener. It does not cover anything reaching the instances another way, and the requirement says regardless.
- D

 Blackhole route
Route tables control where traffic goes, not whether it may arrive. Inbound traffic is not governed by the route you would edit.

DOMAIN 3

'Regardless of what each security group permits' means you need a Deny, and only a NACL has one.

A CloudFront distribution serves objects from an S3 bucket. The objects are encrypted with SSE-KMS using a customer managed key. After migrating the distribution to use an origin access identity, CloudFront returns 403 for every object.

Bucket policy and key policy both reference the origin access identity correctly.

What is the cause?

- ☐ A The KMS key policy must also grant kms:GenerateDataKey to CloudFront
- ☐ B The bucket must have Block Public Access disabled for OAI to work
- ☐ C The distribution must use an S3 website endpoint as its origin
- ☐ D Origin access identity cannot read SSE-KMS encrypted objects; use origin access control

◆ PAUSE AND DECIDE

What is the cause?

- A

 Grant kms:GenerateDataKey
GenerateDataKey is for writing. Serving objects needs Decrypt, and the real problem is that OAI cannot make a SigV4 signed request to KMS at all.
- B

 Disable Block Public Access
Backwards, and dangerous. OAC and OAI both exist so the bucket can stay fully private.
- C

 Use a website endpoint origin
A website endpoint supports neither OAI nor OAC and serves content publicly. This makes the problem far worse.
- D

 OAI cannot read SSE-KMS objects; use OAC
Correct. The single most examinable CloudFront fact – OAI predates SSE-KMS support, and OAC signs origin requests properly.

DOMAIN 3

The word 'migrating' is doing the work – they moved to the older mechanism. SSE-KMS plus CloudFront always means OAC.

Amazon Inspector reports a critical CVE in a base image layer used by 30 container images in Amazon ECR. Roughly 400 tasks running on ECS use those images.

The security team asks how to remediate, with the LEAST operational overhead.

What should the team do?

- ☐ A Patch the base image, rebuild and push the 30 images, and redeploy the ECS services
- ☐ B Use SSM Patch Manager to patch the running containers in place
- ☐ C Add a Network Firewall rule blocking traffic to the vulnerable component's port
- ☐ D Suppress the finding in Inspector and schedule remediation for the next release

◆ PAUSE AND DECIDE

What should the team do?

- A

 Patch the base image, rebuild, redeploy
Correct. Containers are immutable – you fix the image, not the running instance. One base layer fixes all 30 images, which is why this is lowest overhead.
- B

 Patch containers in place
Patch Manager targets managed instances, not containers. A patched container is lost on the next task replacement anyway.
- C

 Block the port at the firewall
A compensating control that may buy time. It does not remediate, and the CVE may be reachable another way.
- D

 Suppress and defer
Suppression hides a critical finding without changing the risk. It makes the dashboard look better.

DOMAIN 3

Containers are immutable. 'Patch the running thing' is always wrong here – and one base layer fixes 30 images at once.

A company must guarantee that no principal outside its AWS Organization can access a set of S3 buckets, including principals in accounts that do not exist yet, and including any bucket policy a local administrator might write in future.

The company already uses SCPs extensively.

What should the company apply?

- ☐ A An SCP denying s3:* when aws:PrincipalOrgID does not match
- ☐ B An RCP denying s3:* when aws:PrincipalOrgID does not match
- ☐ C A bucket policy on each bucket with a PrincipalOrgID condition
- ☐ D IAM Access Analyzer external access findings with automatic archiving

◆ PAUSE AND DECIDE

What should the company apply?

- A

An SCP with PrincipalOrgID

SCPs cap principals inside your organisation. An external principal is not governed by your SCPs at all - this constrains the wrong side.
- C

A bucket policy per bucket

Works today, and is exactly what a local administrator could later overwrite. The requirement anticipates that.
- B

An RCP with PrincipalOrgID

Correct. RCPs cap what may be done to your resources by any principal, including external ones, and sit above any bucket policy an administrator writes.
- D

Access Analyzer with archiving

Detective - it reports external access rather than preventing it. Archiving findings makes it quieter, not safer.

DOMAIN 4

SCPs are a fence around your people. RCPs are a fence around your resources. 'Anyone outside' means RCP.

A company maintains 22 nearly identical IAM policies, one per engineering team, each granting the same EC2 and S3 actions but scoped to resources tagged with that team's name. Adding a team means writing a new policy in every account.

Engineers federate through an external identity provider that already carries a team attribute.

What should the company implement?

- ☐ A One policy per account instead of per team, listing the teams present
- ☐ B A permissions boundary per team, replacing the identity policies
- ☐ C Cognito groups mapped to IAM roles through an identity pool
- ☐ D ABAC: pass the team attribute as a session tag and compare `aws:PrincipalTag` with `aws:ResourceTag` in one policy

◆ PAUSE AND DECIDE

What should the company implement?

- A

 One policy per account
Trades 22 artefacts for one per account, which in a large organisation is more, not fewer – and it still changes when a team is added.
- B

 A boundary per team
The same 22 artefacts renamed. A boundary caps rather than distinguishes, so you still need one per team.
- C

 Cognito groups via an identity pool
Cognito serves application users. These are staff federating from a corporate IdP – Identity Center territory, not Cognito.
- D

 ABAC with session tags and PrincipalTag
Correct. One policy comparing the caller's team tag against the resource tag. Adding a team becomes a group membership change and nothing else.

DOMAIN 4

'22 nearly identical policies differing in one value' is the ABAC signal. So is 'the IdP already carries the attribute'.

A mobile application authenticates users with a Cognito user pool. A new feature requires the app to upload large video files from the device directly to S3, without the bytes passing through the company's API tier.

Each user must be able to write only to their own prefix.

What must be added?

- ☐ A Nothing; the app can call S3 with the user pool access token
- ☐ B An IAM user per application user, with a scoped policy
- ☐ C A Cognito identity pool, exchanging the token for temporary AWS credentials scoped by a policy variable
- ☐ D Presigned URLs generated by the API tier for each upload

◆ PAUSE AND DECIDE

What must be added?

- A

 Call S3 with the access token
S3 does not accept a Cognito token. AWS APIs require SigV4-signed requests with AWS credentials – the gap identity pools exist to close.
- B

 An IAM user per app user
Far past the account quota at mobile scale, and it puts long-lived credentials on devices. The anti-pattern the whole domain argues against.
- C

 An identity pool with a policy variable
Correct. The identity pool converts the user pool token into temporary AWS credentials, and a policy variable gives every user their own prefix under one policy.
- D

 Presigned URLs from the API tier
The strongest distractor – it works and keeps bytes out of the API tier. It needs a round trip per upload, and a presigned URL cannot be revoked once issued.

DOMAIN 4

'Directly from the device' is the phrase that adds an identity pool. Without it, a user pool alone would be enough.

An auditor asks a company to demonstrate that no principal outside its AWS Organization can access a set of IAM roles and KMS keys. The company offers two years of CloudTrail showing no external access occurred.

The auditor says this does not answer the question.

What should the company provide?

- ☐ A Longer CloudTrail retention with Athena queries proving absence of access
- ☐ B IAM Access Analyzer external access findings, with the organisation as the zone of trust
- ☐ C Security Hub CSPM findings for the roles and keys
- ☐ D Policy simulator results for each role against a sample external principal

◆ PAUSE AND DECIDE

What should the company provide?

- A

 More CloudTrail and Athena
More of the evidence the auditor rejected. Absence of observed access proves nobody used a path, not that no path exists.
- B

 Access Analyzer external findings, org as zone of trust
Correct. Automated reasoning proves a statement about every possible request, which is a stronger claim than any amount of history.
- C

 Security Hub CSPM findings
Scores configuration against a standard. A passing control is not a proof about every possible external principal.
- D

 Simulator against a sample principal
Tests the principals you thought to test. The auditor asked about all of them.

DOMAIN 4

Automated reasoning proves; observation only records. That distinction is why logs never satisfy this question.

A financial regulator requires that trade confirmations are retained for five years in a form that cannot be altered or deleted by anyone, explicitly including the account root user and the firm's own administrators. The regulator will audit the technical control.

The firm proposes S3 versioning with a bucket policy denying deletion, plus MFA delete.

What should the firm implement instead?

- ☐ A S3 Object Lock in compliance mode with a five-year retention period
- ☐ B S3 Object Lock in governance mode with a five-year retention period
- ☐ C S3 Glacier Deep Archive with a lifecycle policy preventing early deletion
- ☐ D The firm's proposal, with CloudWatch alarms on any deletion attempt

◆ PAUSE AND DECIDE

What should the firm implement instead?

- A

 Object Lock, compliance mode
Correct. In compliance mode no user can delete or shorten the retention, including the account root user – the requirement stated almost word for word.
- B

 Object Lock, governance mode
The near miss. Governance mode is deliberately bypassable by anyone with `s3:BypassGovernanceRetention`, which is the exception the regulator excludes.
- C

 Deep Archive with lifecycle
A storage class and a cost control. Early-deletion charges discourage deletion rather than preventing it.
- D

 Their proposal plus alarms
Every part is a policy control, and policies are edited by whoever administers them. An alarm tells you afterwards.

DOMAIN 5

'Including the account root user' appears in AWS's own description of compliance mode. That phrase is the answer.

An always-on trading application holds a persistent connection pool to an Aurora cluster. Its database credentials are in Secrets Manager and must rotate every 14 days. During a previous rotation attempt, some connections failed authentication for several seconds. Any failed connection is unacceptable.

What should be configured?

- ☐ A Single-user rotation, with the application caching credentials for 24 hours
- ☐ B A longer rotation window, so the change happens outside trading hours
- ☐ C Alternating-user rotation, cloning from a superuser secret
- ☐ D Move the credentials to Parameter Store and rotate manually every 14 days

◆ PAUSE AND DECIDE

What should be configured?

A Single-user rotation with caching

Single-user rotation changes one credential's password, so there is a moment when a cached value is wrong. Caching lengthens that window rather than removing it.

C Alternating-user rotation

Correct. Two credentials are swapped between, so one is always valid and there is never an instant with no working credential.

B Rotate outside trading hours

An always-on application has no outside hours, and the requirement says any failed connection is unacceptable.

D Parameter Store, rotate manually

Parameter Store has no rotation at all. This replaces an automated process with a human one and does not close the gap.

DOMAIN 5

'Any failed connection is unacceptable' is the phrase that selects alternating-user rotation, every time.

An auditor requires evidence that traffic between EC2 instances inside a VPC is encrypted in transit. The instances are current-generation types. Application-level TLS is not implemented between these services, and the team believes Nitro hardware encryption applies. A packet capture taken on one of the instances shows plaintext.

What should the team provide, and why did the capture show plaintext?

- ☐ A The capture is correct; the traffic is unencrypted and TLS must be added
- ☐ B Config rules confirming the instance types support encryption in transit
- ☐ C GuardDuty findings showing no interception of the traffic
- ☐ D VPC Flow Logs with the encryption-status field; the capture is above the Nitro card, which encrypts below the OS

◆ PAUSE AND DECIDE

What should the team provide, and why did the capture show plaintext?

- A

The capture is correct

The trap. Nitro encryption happens in the Nitro card, below the OS, so a host capture shows plaintext whether or not encryption occurs.
- C

GuardDuty findings

Absence of a detection is not evidence of encryption. GuardDuty does not report on in-transit encryption at all.
- B

Config rules on instance types

Proves the instances are capable, which is necessary and not sufficient. It says nothing about whether a given flow was encrypted.
- D

Flow Logs encryption-status; capture is above the Nitro card

Correct. The field reports per flow whether encryption came from Nitro hardware, TLS, both or neither – and explains the wrong vantage point.

DOMAIN 5

Encryption below the OS means the host is exactly the wrong place to look for it.

A telemetry pipeline writes about 300 million small objects a month to an S3 bucket encrypted with SSE-KMS under a customer managed key. KMS request charges now exceed the S3 storage charges.

Security requires the data stay under a customer managed key the company can disable, and that key usage remains auditable.

What should the pipeline team do?

- ☐ A Enable S3 Bucket Keys on the bucket
- ☐ B Switch the bucket to SSE-S3
- ☐ C Switch to SSE-C, which incurs no KMS charges
- ☐ D Move the bucket to a Region with lower KMS pricing

◆ PAUSE AND DECIDE

What should the pipeline team do?

- A** Enable S3 Bucket Keys
Correct. Up to 99% fewer KMS requests under the same customer managed key. The audit trail becomes coarser - bucket ARN rather than object ARN - not absent.
- B** Switch to SSE-S3
Removes the charge and the control. Security requires a key the company can disable, and SSE-S3 keys are AWS's.
- C** Switch to SSE-C
Removes KMS charges and every auditable record of key use, needs the key on every request, and is blocked by default on new buckets since April 2026.
- D** A cheaper Region
Moves 300 million objects to save a fraction per request, and does nothing about the request volume that is the actual cause.

DOMAIN 5

Two security requirements survive the cost problem. Only Bucket Keys keeps both a disableable key and an audit trail.

An organisation runs AWS Control Tower with detective controls applied to all OUs. A quarterly review reports 100% compliance. An internal red team then finds several non-compliant resources in ap-south-2 and eu-south-2.

The controls are correctly applied and show no violations.

What is the explanation?

- ☐ A Detective controls evaluate only the account's home Region
- ☐ B Detective controls apply only in Regions that Control Tower supports; unsupported Regions are not evaluated
- ☐ C The red team's resources were created after the last evaluation cycle
- ☐ D Detective controls exclude resources not created by Account Factory

◆ PAUSE AND DECIDE

What is the explanation?

- A

 Home Region only
Too narrow. Detective controls cover the Regions Control Tower governs, which is more than one – the boundary is support, not a home Region.
- B

 Only in Control Tower-supported Regions
Correct. A resource in an unsupported Region is not evaluated at all, so it shows no violation – and 100% compliance means 100% of what was assessed.
- C

 Created after the last cycle
The Config rules behind detective controls evaluate on change and periodically. A timing gap does not produce a clean report across two Regions.
- D

 Excludes non-Account Factory resources
Invented. Controls apply to accounts and evaluate resources regardless of how they were created.

DOMAIN 6

'100% compliant' means 100% of what was evaluated. Silence from an unevaluated Region is not compliance.

A start-up created its AWS account this year and must produce SOC 2 evidence for its first audit. An engineer reads that AWS Audit Manager has a SOC 2 framework, but cannot enable the service.

The team asks what AWS offers instead.

What should they be told?

- ☐ A Enable Audit Manager in a different Region, where it remains available
- ☐ B Download AWS Artifact's SOC 2 report, which satisfies the audit
- ☐ C Enable the Security Hub CSPM SOC 2 standard, which replaced the framework
- ☐ D Audit Manager closed to new accounts on 30 April 2026; AWS points to Config conformance packs, which have no SOC 2 template

◆ PAUSE AND DECIDE

What should they be told?

- A

 Try another Region
The restriction is on new accounts, not Regions. A new account cannot set it up anywhere.
- B

 Artifact's SOC 2 report
Documents AWS's compliance, not the start-up's. It belongs in the audit and does not answer it.
- C

 Security Hub CSPM SOC 2 standard
There is no such standard. Security Hub CSPM covers AWS FSBP, CIS, PCI DSS and NIST 800-53.
- D

 Closed to new accounts; conformance packs, and no SOC 2 template
Correct, and honest about the gap. AWS names SOC 2 and GDPR as the most notable absences from conformance pack templates.

DOMAIN 6

The complete answer includes a gap AWS acknowledges. Partner tooling fills it, alongside Config.

A company enables centralised root access and removes root credentials from all member accounts. Its CIS-aligned alarm on root user ConsoleLogin events has fired zero times in five months, and the security lead reports this as evidence that privileged access has ceased. The organisation performs roughly four privileged member-account operations a month.

What is wrong with the conclusion?

- ☐ A Root ConsoleLogin events are not recorded in CloudTrail
- ☐ B The alarm should cover the management account only
- ☐ C No member root users remain to sign in; privileged access now runs through sts:AssumeRoot, which the alarm does not watch
- ☐ D Nothing is wrong; zero alerts correctly indicates zero privileged access

◆ PAUSE AND DECIDE

What is wrong with the conclusion?

- A

 Not recorded in CloudTrail
Root activity is logged like any other principal, and alarming on it is a standard benchmark control. The alarm worked; its subject disappeared.
- B

 Management account only
Half right – the management account root does still exist and needs alarming. It misses that member-account privileged access moved rather than stopped.
- C

 Privileged access moved to sts:AssumeRoot
Correct. The question tells you four privileged operations happen monthly. Alarm on AssumeRoot, which carries SourceIdentity and is a better trail than root sign-in.
- D

 Zero alerts means zero access
The conclusion being tested. The alarm watches an event that can no longer occur, so its silence carries no information.

DOMAIN 6

A security improvement silenced a detective control. The scenario tells you the activity continues – only the alarm stopped seeing it.

Scoring practice exam 2

- ◆ **Answer key:** C A B D B C A D A B D C B A C D A B D C.
- ◆ **Domains here:** Q1-3 detection, Q4-6 incident response, Q7-9 infrastructure, Q10-13 identity, Q14-17 data protection, Q18-20 governance.
- ◆ **Q1, Q18 and Q20 share a shape:** a control reporting nothing because it was never watching. Silence is not compliance.
- ◆ **Q2, Q5, Q9 and Q12 each had a strong near miss** that is correct for a slightly different requirement. Check you can name why yours lost.
- ◆ If you scored below 15, work the domain you lost most in before taking exam 3.

ON THE EXAM

Next: practice exam 3, with a heavier detection weighting.